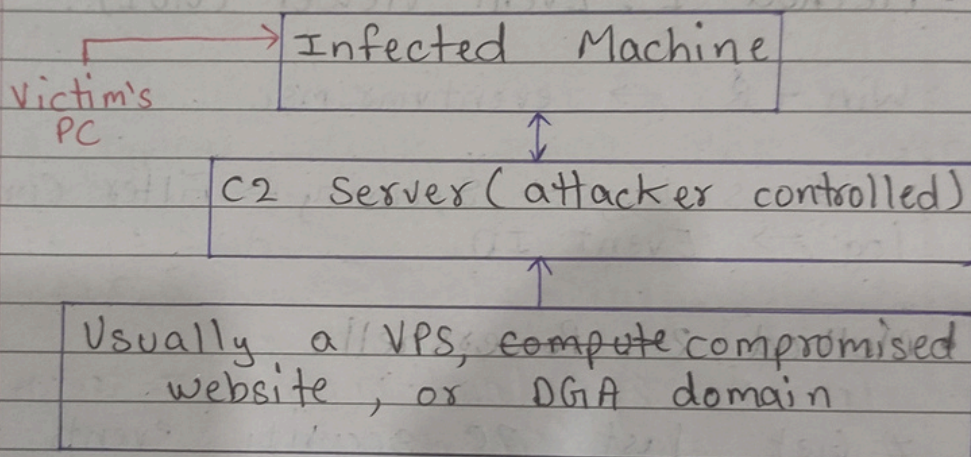


Day: 16

* What is C2 Traffic?

- C2 (Command and Control) is how malware communicates with the attacker after infecting a machine. The attacker sends commands TO the malware, and the malware sends stolen data BACK.



* The 5 C2 Traffic Patterns

1) Beaconsing

Malware checks in with its C2 server at regular intervals — like a heartbeat.

10:00:00 → C2 server

10:00:60 → C2 server (exactly 60 seconds later)

10:02:00 → C2 server (exactly 60 seconds later)

10:03:00 → C2 server

- How to spot it: IO Graph shows regular spikes. Conversations tab shows many connections to one IP.

at equal intervals.

- DFIR filter: `ip.dst == [suspicious IP]`

2) DGA - Domain Generation Algorithm

Instead of hardcoding a C2 domain (which can be blocked), malware generates random domains daily from an algorithm, so only they know the algorithm (attacker & malware) and also only they know what domain to use each day.

Day 1: `xkq7z3mpa.ru`

Day 2: `mzp9qw2nx.com`

Day 3: `hbt5k18yz.net`

- How to spot it:

1) Very long random-looking domain names.

2) High NXDOMAIN (no such name) count - malware tries many domains until it finds the live one.

3) Domain with unusual TLDs (.ru, .tk, .xyz)

- DFIR filter: `dns and dns.flags.rcode==3`
(NXDOMAIN responses)

3) HTTP POST Exfiltration

Malware sends stolen data (keystroke files, credentials) to C2 using HTTP POST requests — same as submitting a web form, but the "form data" is your stolen information

POST /gate.php HTTP/1.1

HOST: 185.220.X.X

User-Agent: Mozilla/4.0 (fake browser)

Content: [encrypted stolen data]

• How to spot it:

1) POST to unusual URLs (/gate.php, /panel/, /b374k.php)

2) POST to bare IP address (no domain)

3) Unusual or fake User-Agent strings

4) Large Content — Length in POST

• DFIR filter: `http.request.method == "POST"`

4) HTTPS C2 (Encrypted Beacons)

Modern malware uses HTTPS to hide C2 traffic in encrypted traffic. You can't see the content —

but you can see:

- The domain via SNI in TLS Client Hello.
- Regular connection timing (beaconing)
- Certificate anomalies (self-signed, wrong domain)
- DFIR filter: `tls.handshake.type == 1`
CClient Hello - shows SNI

5) DNS Tunneling

Attacker hides data inside DNS queries — using subdomains to smuggle data out:

Normal DNS : query → google.com
Tunneling : query → 5468657468696566.
c2domain.com

This is hex-encoded stolen data ↑

- How to spot it :

- 1) Extremely long subdomain names (>50 chars)
- 2) High volume of DNS queries to one domain
- 3) DNS query sizes much larger than normal (normal = ~30 bytes, tunneling)

= 100 + bytes)

- DFIR Filter: `dns.qry.name.len > 50`

* C2 Traffic vs Normal Traffic

Feature	Normal Traffic	C2 Traffic
DNS queries	known domains	Random/DGA domains
Timing	Irregular	Regular (beaconing)
HTTP POST	Form submissions	Stolen data
User-Agent	Real browser	Fake / unusual
Destination	CNAs, known servers	Unknown IPs
Volume	Varies	Consistent (beacon)
Certificates	Trusted CAs	Self-signed

* Real Malware C2 Patterns

Malware	C2 Method	What to look for
Emotet	HTTP POST	POST to WordPress sites, fake User-agent

Cobalt Strike	HTTPS beacon	Regular HTTPS every 60s, malleable C2
Trickbot	HTTPS	Many IPs, certificate anomalies
Sakbot	HTTPS + DNS	DGA domains, HTTPS beaconing
IcedID	HTTPS	GET requests with encoded data in URL
AsyncRAT	TCP direct	Connection to port 4444 or 6606

* Key DFIR Filters for C2 Hunting

- `dns.flags.rcode == 3` → NXDOMAIN - DGA failure
- `http.request.method == "POST"` → Data exfiltration
- `http.user_agent` → Fake user agents
- `tls.handshake.type == 1` → C2 domain via SNI
- `tcp.port == 4444` → Metasploit C2
- `dns.qry.name.len > 50` → DNS tunneling
- `ip.dst == x.x.x.x` → Traffic to specific C2 IP

- frame contains "gate.php" → Common C2 URL

* Diagrams:

1) C2 Traffic Patterns — 5 Ways Malware Communicates:

Infected PC	C2 Traffic	C2 server
Victim machine	Commands back	Attacker controlled

1) Beaconsing

Regular time check
-ins IO Graph = heartbeat

2) DGA Domains

Random domain names
High XDOMAIN count

3) HTTP POST Exfil

Stolen data sent OUT
POST to /gate.php, fake UA

4) HTTPS C2

Encrypted beaconsing
Check SNI in Client Hello

5) DNS Tunneling

Data in DNS queries
Long subdomains
(> 50 chars)

C2 Signs

Regular timing,
unknown IPs DGA
domains, fake UA

LAB — Step by Step:

1. Go to <https://malware-traffic-analysis.net>
2. Download a PCAP
3. Open in Wireshark
4. Look for:

Step 1 — DGA Domains:



MALWARE-TRAFFIC-ANALYSIS.NET

TRAFFIC ANALYSIS EXERCISES

NOTES:

- If you're new to these exercises, start from the most recent and work your way back.
- Do **not** start with the oldest ones first!
- Malware and malware traffic is constantly evolving, so the further back you go, the less these exercises reflect our current threat landscape.
- Also, I grew better at creating these, so the earliest ones are not as good for training.

EXERCISE LINKS:

- **2026-08-09** – Traffic analysis exercise: **First to Last**
- **2026-02-28** – Traffic analysis exercise: **Easy as 123**
- **2026-01-31** – Traffic analysis exercise: **Lumma in the Room-ah!**
- **2025-06-13** – Traffic analysis exercise: **It's a trap!**
- **2025-01-22** – Traffic analysis exercise: **Download from fake software site**
- **2024-11-26** – Traffic analysis exercise: **Nemotodes**
- **2024-09-04** – Traffic analysis exercise: **Big Fish in a Little Pond**
- **2024-08-15** – Traffic analysis exercise: **WarmCookie**
- **2024-07-30** – Traffic analysis exercise: **You dirty rat!**
- **2023-07** – Crossing the Line: **Unit 42 Wireshark Quiz for RedLine Stealer**
- **2023-07** – RedLine Stealer: **Answers to Unit Wireshark Quiz**
- **2023-04** – Cold as Ice: **Unit 42 Wireshark Quiz for IcedID**
- **2023-04** – Cold as Ice: **Answers to Unit 42 Wireshark Quiz for IcedID**
- **2023-03** – Finding Gozi: **Unit 42 Wireshark Quiz, March 2023**
- **2023-03** – Finding Gozi: **Answers to Unit 42 Wireshark Quiz, March 2023**
- **2023-02** – Unit 42 Wireshark Quiz, **February 2023**
- **2023-02** – **Answers to Unit 42 Wireshark Quiz, February 2023**
- **2023-01** – Unit 42 Wireshark Quiz, **January 2023**
- **2023-01** – **Answers to Unit 42 Wireshark Quiz, January 2023**
- **2022-03-21** – Traffic analysis exercise - **Burnincandle**
- **2022-02-23** – Traffic analysis exercise - **Sunnystation**

Protocol	Length	Info
DNS	75	Standard query 0xa3b0 A wpad.mshome.net
DNS	161	Standard query response 0xa3b0 No such name A wpad.mshome.net SOA ns1-35.azure-dns.com
DNS	81	Standard query 0xb65f HTTPS config.edge.skype.com
DNS	81	Standard query 0x46fd A config.edge.skype.com
DNS	244	Standard query response 0x46fd A config.edge.skype.com CNAME config.edge.skype.com.trafficmanager.net CNAME ln-0007.config.skype.com CNAME config-edge-skype.ln-0007.ln-msedge.net CNAME ..
DNS	72	Standard query 0xf45a HTTPS www.bing.com
DNS	72	Standard query 0x1333 A www.bing.com
DNS	228	Standard query response 0xb65f HTTPS config.edge.skype.com CNAME config.edge.skype.com.trafficmanager.net CNAME ln-0007.config.skype.com CNAME config-edge-skype.ln-0007.ln-msedge.net CNL
ICMP	256	Destination unreachable (Port unreachable)
DNS	337	Standard query response 0x1333 A www.bing.com CNAME www-www.bing.com.trafficmanager.net CNAME www.bing.com.edgekey.net CNAME e86303.dscx.akamaiedge.net A 23.222.241.141 A 23.222.241.147..
DNS	254	Standard query response 0xf45a HTTPS www.bing.com CNAME www-www.bing.com.trafficmanager.net CNAME www.bing.com.edgekey.net CNAME e86303.dscx.akamaiedge.net SOA m8dscx.akamaiedge.net
DNS	246	Standard query response 0x6f90 A assets.msn.com CNAME assets.msn-com-world-atm-default.trafficmanager.net CNAME assets.msn.com-ion.edgesuite.net CNAME al666.dscr.akamai.net A 23.47.48.5..
DNS	79	Standard query 0x16da A assets.adobedtm.com
DNS	79	Standard query 0x16da A assets.adobedtm.com
DNS	179	Standard query response 0x16da A assets.adobedtm.com CNAME cn-assets.adobedtm.com.edgekey.net CNAME e7808.dscg.akamaiedge.net A 184.29.31.84
DNS	80	Standard query 0xc94f A wpad.win11office.com
DNS	158	Standard query response 0xc94f No such name A wpad.win11office.com SOA win-lu4124x3ub7.win11office.com
DNS	75	Standard query 0x793d A wpad.mshome.net
DNS	161	Standard query response 0x793d No such name A wpad.mshome.net SOA ns1-35.azure-dns.com
DNS	78	Standard query 0xd3cb HTTPS edge.microsoft.com
DNS	78	Standard query 0x72f6 A edge.microsoft.com
DNS	78	Standard query 0x9912 HTTPS edge.microsoft.com
DNS	78	Standard query 0x4428 A edge.microsoft.com
DNS	83	Standard query 0xb375 A odc.officeapps.live.com

Step 2 – Data Exfiltration:

http.request.method == "POST"

No.	Time	Protocol	Length	Info
1197	POST	/api/set_agent?id=38f67ec85328c57295788e4c8a0df174c&token=842e2082df0f0a0b04ed51f12f4387e761523b&description=Agent-Chrome&act=log	HTTP/1.1	(application/x-www-form-urlencoded)
1149	POST	/api/set_agent?id=38f67ec85328c57295788e4c8a0df174c&token=842e2082df0f0a0b04ed51f12f4387e761523b&description=Agent-Edge&act=log	HTTP/1.1	(application/x-www-form-urlencoded)

Step 3 – C2 over HTTP:

http

No.	Time	Source	Destination	Protocol	Length	Info
72	2.359200			HTTP	165	GET /connecttest.txt HTTP/1.1
74	2.480424			HTTP	241	HTTP/1.1 200 OK (text/plain)
23861	96.699789			HTTP	465	GET /file?/current?os=rev01-b500vskiyim870a-vx0081KCH8r7Jm5h9P0F0o0E8cu2hreq-e3b0c44298fc1c149afb4c8996f092427ae4146490934ca495991b7852b855 HTTP/1.1
24500	95.344558			HTTP	683	GET /api/set_agent?id=38f67ec85328c57295788e4c8a0df174c&token=842e2082df0f0a0b04ed51f12f4387e761523b&description=Agent-Chrome HTTP/1.1
24525	95.660559			HTTP	74	HTTP/1.1 200 OK (text/html)
24601	96.287894			HTTP	1197	POST /api/set_agent?id=38f67ec85328c57295788e4c8a0df174c&token=842e2082df0f0a0b04ed51f12f4387e761523b&description=Agent-Chrome&act=log HTTP/1.1 (application/x-www-form-urlencoded)
24614	96.485931			HTTP	546	GET /favicon.ico HTTP/1.1
24616	96.505591			HTTP	74	HTTP/1.1 200 OK (text/html)
24619	96.669281			HTTP	428	HTTP/1.1 404 Not Found (text/html)
24638	100.156887			HTTP	436	GET /api/set_agent?id=38f67ec85328c57295788e4c8a0df174c&token=842e2082df0f0a0b04ed51f12f4387e761523b&description=Agent-Chrome HTTP/1.1